Threat and Vulnerability Identification Template

Use this template to identify key assets, associated threats, potential vulnerabilities, and initial ideas for mitigation. This exercise helps build foundational skills in cybersecurity risk assessment.

Asset Name	Asset Description	Associated Threats	Potential Vulnerabilities	Mitigation Notes
Customer data	names, emails, phone numbers, and addresses	Data leaks, phishing. Ransomware attack	Poor data handling, fake emails	Data encryption
Tokenized payment details	Credit card number, name, expiration date, pin	Phishing, ransomware, data skimming, third party vendor breach	Insecure API key handling	Data encryption
Staff credentials	Staff name, email, password, VPN login, role based access	Phishing, malware, password sharing, social engineering	Poor data handling, fake emails, unchanged default credentials	Credential monitoring
Behavior analytics	Information of how often customers visit the site, when they make purchases, what items are bought together	Data exfiltration, brute-force attacks, ransomware, compromised accounts	Overwhelm systems with irrelevant events	Zero trust and regular security training
Purchase history	Information of how often customers make purchase, what is purchased and what they could	Privacy violations, doxxing, targeted scams, identity theft	Insecure Direct Object Reference	Use transactional history to fine tune fraud detection
Loyalty program data	Customer ID, purchases, and how long they have been customers	Phishing, internal fraud, data breach, device spoofing, policy and member misuse	Credential stuffing, phishing, and brute-force attacks	Multifactor identification

Risk Criteria

The below explains what each item in the Risk Assessment means.

Criteria	Description
Risk Description	Detailed explanation of the scenario, what could go wrong, and why it matters.
Assets at Risk	The information, system, or service impacted (e.g., customer data, VDI environment).
Threat	Who or what could cause the risk (e.g., insider, cybercriminal, accident, malware). The action or event (e.g., data exfiltration, privilege misuse, physical theft).
Vulnerability	Weakness – the gap or condition that enables the threat (e.g., extended idle session, clipboard sharing).
Existing Controls	Current safeguards in place (e.g., MFA, logging, endpoint DLP).
Inherent Risk Rating	Risk level before any mitigations are applied.
Residual Risk Rating	Risk level after current controls are considered.
Likelihood	The probability of occurrence (e.g., Rare, Possible, Likely).
Consequence	Severity – level of damage if realized (e.g., Minor, Moderate, Major, Extreme).
Rating	The outcome of the risk likelihood and consequence evaluation.
Mitigations	Treatment Plan – actions to reduce, transfer, avoid, or accept the risk.
Risk Owner	Person or role accountable for managing the risk (e.g., the person who uses the software)

Risk Assessment

Complete this assessment for at least 3 risks.

Risk Details			
Risk ID	001	**Date Identified**	2023
Risk Title	Customer service phishing attack	**Review Date**	2023
Risk Identification			
Risk Description	A phishing attack aimed at customer service representatives could result in credential compromise and loss of access to the system		
Assets at Risk	Customer data and credential compromise		
Threat	Cybercriminal using phishing attack		
Vulnerability	Customer service's lack of cybersecurity training		
Existing Controls	BYOD policy		

Inherent Risk Analysis		
Likelihood	**Consequence**	**Inherent Risk Rating**
Possible	Moderate	Medium
Residual Risk Analysis		
Likelihood	**Consequence**	**Residual Risk Rating**
rare	Minor	Low

Risk Treatment	
Mitigations	Phishing attack awareness training
Risk Monitoring and Review	
Risk Owner	Customer relationship management

To	Customer service department

Cc	Customer service manager
Bcc	Customer service staff
Subject	Mandatory phishing awareness training

Hello,

The RetailNova Security Team would like to inform customer service staff to please attend the phishing email awareness training next week. It will be a short meeting to aid staff in identifying potential malicious emails to prevent the phishing attack from 2023.

For any questions or issues, don't hesitate to reach out to us.

Kind regards,
RetailNova Security Team

Risk Details: Ransomware Attack			
Risk ID	002	**Date Identified**	2024
Risk Title	Ransomware attempt	**Review Date**	2024
Risk Identification			
Risk Description	A ransomware attack was aimed to prevent staff from accessing the company system, causing the system to be unavailable for an unknown amount of time and affecting sales.		
Assets at Risk	Customer data, sales		
Threat	Cybercriminal, malware loss of critical information and data, costly disruptions to operations and business		
Vulnerability	Corporate staff are allowed to use their own devices under a BYOD policy		

Existing Controls	Endpoint protection	
Inherent Risk Analysis		
Likelihood	**Consequence**	**Inherent Risk Rating**
Possible	Major	High
Residual Risk Analysis		
Likelihood	**Consequence**	**Residual Risk Rating**
Unlikely	Minor	Low
Risk Treatment		
Mitigations	Endpoint protection	
Risk Monitoring and Review		
Risk Owner	RetailNova	

To	Person Person Person
Cc	Person
Bcc	Person
Subject	BYOD policy update

Hello,

The RetailNova Security Team would like to inform staff to please update their personal devices and continue using the VPN when accessing the internal systems remotely.

For any questions or issues, don't hesitate to reach out to us.

Kind regards,
RetailNova Security Team

Risk Details: Third party data leak

Risk ID	003	**Date Identified**	2025
Risk Title	Data leak	**Review Date**	2025
Risk Identification			
Risk Description	A third party marketing vendor had a data leak exposing the email addresses of 5,000 customers, leading to a loss of confidentiality and integrity		
Assets at Risk	Customer data		
Threat	Accident, data exfiltration		
Vulnerability	Utilizing a third party for marketing		
Existing Controls	Firewall and antivirus		
Inherent Risk Analysis			
Likelihood	**Consequence**	**Inherent Risk Rating**	
Unlikely	Minor	Low	
Residual Risk Analysis			
Likelihood	**Consequence**	**Residual Risk Rating**	
Rare	Insignificant	Low	
Risk Treatment			
Mitigations	Chose a different third party marketing vendor with emphasis on DLP strategies		
Risk Monitoring and Review			
Risk Owner	Third party marketing vendor		

To	Person Person Person
Cc	Person

Bcc	Person
Subject	Renegotiate

Hello,

It has come to our attention that there was a data leak exposing 5,000 of our customers's emails. We hope to address the situation, discuss mitigation solutions, and potentially increase DLP strategies.

For any questions or issues, don't hesitate to reach out to us.

Kind regards,

RetailNova

Cybersecurity Risk Prioritization Matrix

Understanding the Likelihood Rating

The table below provides the categories and ratings for likelihood:

Likelihood Ratings	Description	Criteria
Rare (1)	Exceptional circumstances only	May occur only in very unusual situations
Unlikely (2)	Possible, but not expected	Could happen but not typical; requires specific conditions (e.g., targeted phishing bypassing all filters).
Possible (3)	Might occur at some point	Has occurred in similar organizations; realistic but not frequent (e.g., ransomware attempt on enterprise endpoint).
Likely (4)	Will probably occur in most circumstances	Expected to happen periodically (e.g., phishing emails, credential stuffing attempts).
Almost Certain (5)	Expected to occur frequently	Has occurred multiple times, highly predictable (e.g., malware probes, daily scanning activity).

Understanding the Consequence Ratings Table

The table below provides the categories and ratings for impacts:

Consequence Rating	Description	Criteria
Insignificant (1)	Negligible impact	No compromise of sensitive data, no disruption, minimal financial or reputational impact.
Minor (2)	Small impact	Limited operational disruption; minimal data exposure (non-sensitive data); easily contained.
Moderate (3)	Noticeable impact	Partial service disruption; limited sensitive data exposure; moderate cost or compliance breach.
Major (4)	Severe impact	Significant outage of critical systems; large-scale sensitive data breach; regulatory non-compliance with penalties.
Extreme (5)	Catastrophic impact	Extended enterprise-wide outage; compromise of PROTECTED/SECRET data; severe financial/reputational damage; possible criminal or regulatory prosecution.

The 5×5 Risk Matrix

Use this 5×5 risk matrix to evaluate and prioritize cybersecurity risks. For each identified risk, assess its likelihood (1 = Rare, 5 = Almost Certain) and impact (1 = Insignificant, 5 = Critical). Plot the risk in the matrix and use the result to guide mitigation priorities.

Risk Levels

Likelihood ↓ Impact →	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Extreme (5)
5 – Almost Certain	**MEDIUM**	**HIGH**	**HIGH**	**EXTREME**	**EXTREME**
4 – Likely	**MEDIUM**	**MEDIUM**	**HIGH**	**HIGH**	**EXTREME**
3 – Possible	**LOW**	**MEDIUM**	**MEDIUM**	**HIGH**	**HIGH**

Likelihood ↓ Impact →	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Extreme (5)
2 – Unlikely	**LOW**	**LOW**	**MEDIUM**	**MEDIUM**	**HIGH**
1 – Rare	**LOW**	**LOW**	**LOW**	**MEDIUM**	**MEDIUM**

- **Low** – Acceptable; manage by routine controls and monitoring.
- **Medium** – Requires management attention; additional controls may be needed.
- **High** – Significant; must be treated with priority, monitored closely, and escalated to senior management.
- **Extreme** – Unacceptable; immediate executive-level attention and remediation required.

Tips for Completing the Matrix

— Start by identifying the risk scenario (e.g., data breach, system outage).
— Assign a likelihood score based on how often this type of risk occurs.
— Assign an impact score based on potential damage to operations, reputation, or finances.
— Use the matrix to prioritize: risks in the top-right corner (high likelihood and impact) need urgent attention.